CHALMERS

Security Risks of Crafting Allowlists for Phishing Awareness and Simulated Attacks

Anas Masri & Venkata Sai Sarat Chandra Yellapragada
Supervisors: Victor Morel & Xiuqi Zhang
Chalmers University of Technology

2026-06-12

Outline

Introduction & Background

Methodology & Setup

Results

Conclusion

CHALMERS

Introduction & Background

Methodology & Setup

Results

Conclusion

Introduction

- Phishing remains a top vector for data breaches and credential theft (CISA).
- Organizations use Security Awareness Training (SAT) to test and train employees.
- To make these simulated attacks work, companies must modify their security filters so the fake phishing emails reach user inboxes.

Vulnerability Found by Eye Security



Source: Eye Security (2023) [1]

Problem with Allowlists

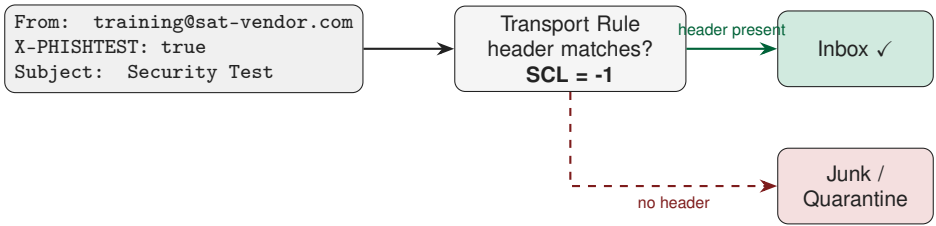
CHALMERS

- SAT platforms require clients to bypass spam and phishing filters using allowlists (IPs, domains, or custom headers).
- These configurations prioritize the reliable delivery of training emails over strict security.
- Attackers might exploit these relaxed settings to bypass defenses and deliver real threats during or outside of training windows.

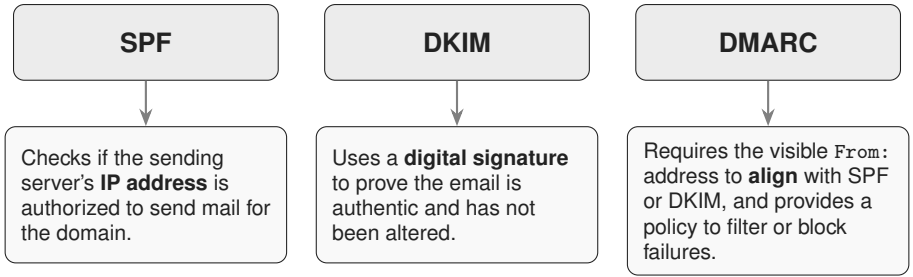
Background: Header-Based Allowlisting

CHALMERS

- SAT vendors instruct IT to add an **Exchange Transport Rule (ETR)**: *if a message carries a custom header (e.g. `X-PHISHTEST: true`), set `SCL = -1`* → skip spam/phishing filtering.
- The header is just a text label in the message. It is *not* authenticated. Any sender can add it.



Background: Email Authentication



These protocols work together to verify the sender's identity and protect the integrity of the message.

Research Questions

- **RQ1:** Can attackers bypass the security measures by spoofing headers like `X-PHISHTEST`?
- **RQ2:** Can attackers abuse a SAT vendor's shared infrastructure (e.g., SendGrid) to deliver malicious mail?
- **RQ3:** How many default SAT domains are unregistered and vulnerable to takeover?

Threat Model

CHALMERS

Threat actor	Motivation	Capabilities	Impact
Allowlist Abuse (External)	Land phishing emails and steal credentials	Forge SMTP headers (e.g., `X-PHISHTEST`) and spoof senders	Bypasses reputation and content-based email filters
Platform access (External)	Exploit vendor trust for high-deliverability phishing	Register or compromise accounts on shared email infrastructure	Evades network-level blocks by inheriting IP allowlist trust
Domain Lifecycle (External)	Run stealthy, persistent phishing operations	Register expired SAT domains and control their DNS	Bypasses domain filtering by exploiting historical trust
Misconfig (Internal)	Ensure SAT delivery and reduce admin overhead	Create overly broad exceptions (e.g., SCL=-1, wide IP ranges)	Creates permanent blind spots in email defenses

Related Work - NDSS 2024: BreakSPF

CHALMERS

- Exploits SPF's (Sender Policy Framework) reliance on IP validation in shared environments (cloud providers, CDNs, email relays) to bypass email authentication.
- This research is related to our experiments on shared infrastructure abuse, proving that trusting infrastructure (IPs) rather than sender identity is a dangerous vulnerability.

TABLE V. TOP 10 WELL-KNOWN DOMAINS INFLUENCED BY BYPASSSPF ATTACK.

Domain	Rank	IP	Source
microsoft.com	5	20.*.*.30	CI/CD Platforms
qq.com	11	114.*.*.86	Cloud Servers
csdn.net	76	114.*.*.86	Cloud Servers
huanqiu.com	110	114.*.*.86	Cloud Servers
godaddy.com	142	72.*.*.69	Tor
rednet.cn	306	114.*.*.86	Cloud Servers
mama.cn	311	114.*.*.86	Cloud Servers
zhihu.com	420	114.*.*.86	Cloud Servers
ieee.org	523	201.*.*.173	RESIP
ucla.edu	610	131.*.*.85	VPN

Source: [2]

Introduction & Background

Methodology & Setup

Results

Conclusion

Experimental Procedure

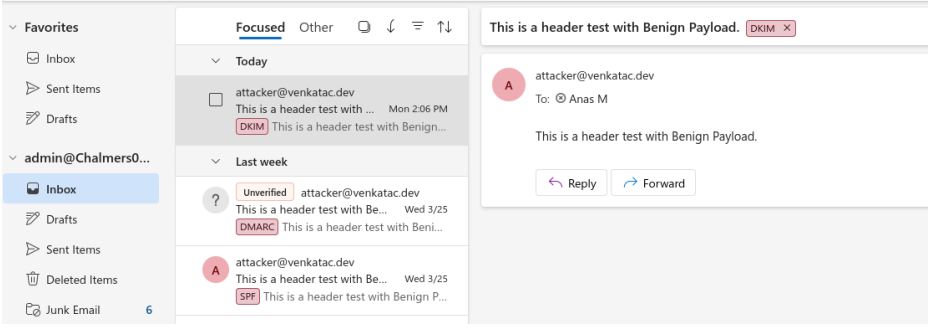
CHALMERS

1. **Phase 1:** Baseline Establishment
2. **Phase 2:** Header Spoofing
3. **Phase 3:** Shared Infrastructure Abuse
4. **Phase 4:** Domain Analysis
5. **Phase 5:** Production Validation

Target Environment

Target Environment: Dedicated Microsoft 365 E3 Sandbox.

- Configured with custom Exchange Transport Rules (ETRs) to simulate allowlists.



Exchange Admin Center

CHALMERS

Rules

Add, edit, or make other changes to your transport rules. Learn more about transport rules

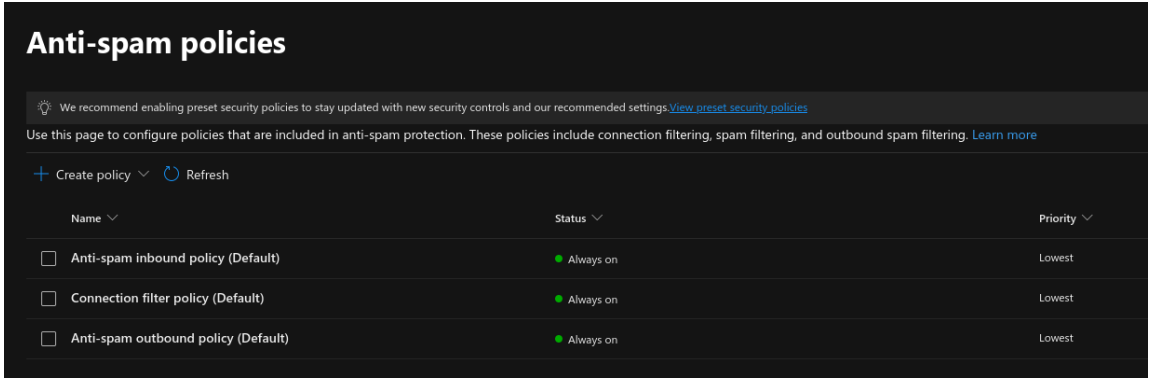
+ Add a rule | Edit | Duplicate | Refresh | Move up | Move down

Status	Rule	Priority	Stop processing rules	Size (Bytes)	Last execution	Configuration suppo...	Unsupported reason
Enabled	Header	0	✓	451	5 days ago	✓	
Disabled	IP Allowlisting	1	✓	757	6 days ago	✓	
Disabled	Domain Allowlisting	2	✓	380	5 days ago	✓	

Default Security Posture

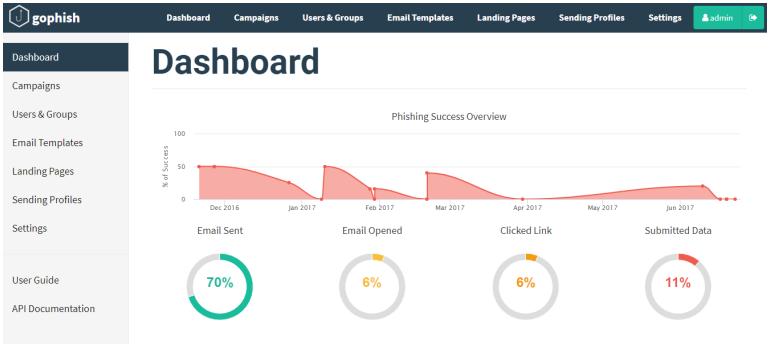
- Before introducing SAT allowlists, we verified the default Microsoft Defender protection stack was active.
- Instead of modifying these core anti-spam policies, we used Exchange Transport Rules (ETRs) to create allowlists for specific IPs and headers.

Default Security Posture



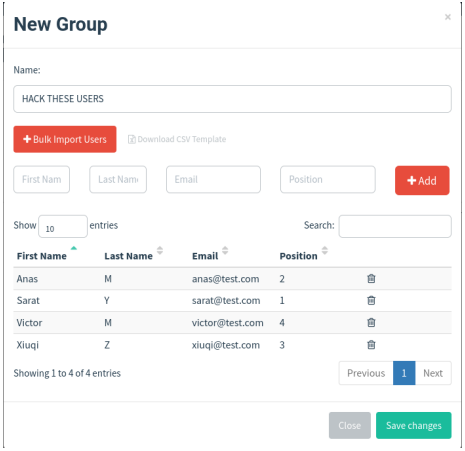
Attacker Environment

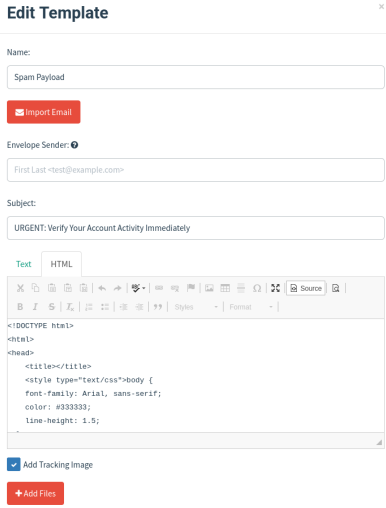
- Open-source tool called **GoPhish** hosted on a Linux Machine.
- Used for campaign management and standardizing payload delivery.
- Since our research is about security rather than social behavior of users, we ignore these statistics.



GoPhish

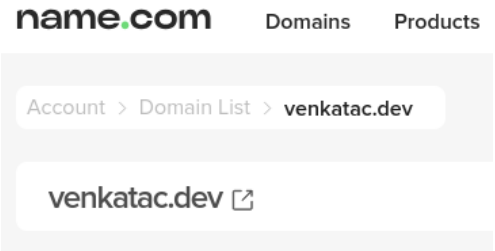
CHALMERS





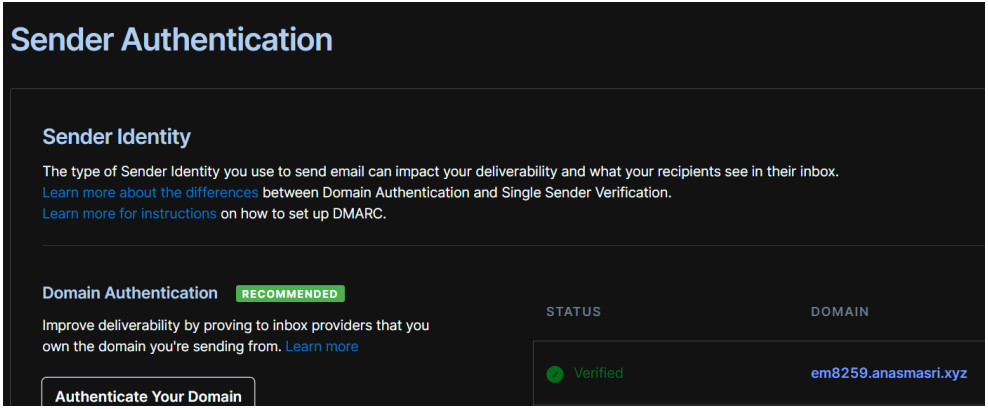
Delivery Infrastructure: name.com

- Created two domains on name.com for sending emails.
- One email to simulate SAT provider and the other to simulate the Attacker.



Delivery Infrastructure: SendGrid

- **Shared Email Relays**: Used as the shared cloud email provider to test IP allowlisting.



Payload Strategy

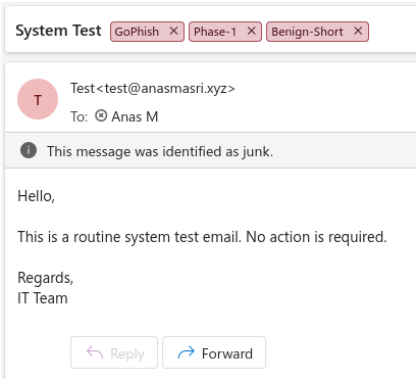
CHALMERS

We standardized payloads to isolate how allowlists process emails:

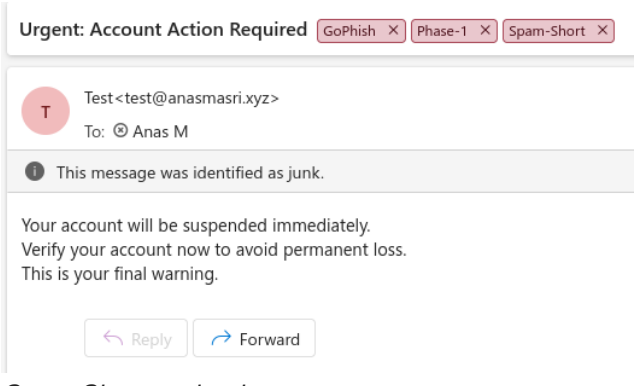
- **Payload 1:** Benign text.
- **Payload 2:** Spam keywords like "Urgent Action Required".
- **Payload 3:** Simulated Phish (URL link with text such as "Click here to verify").
- **Payload 4:** Simulated Malware (EICAR string as an attachment).

We have two versions for each payload: short and long

Payload Strategy

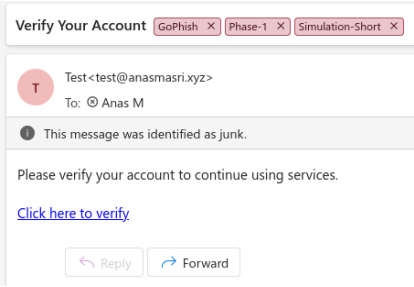


Benign Short payload

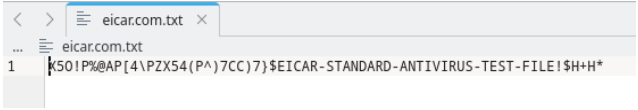


Spam Short payload

Payload Strategy



Simulation Short payload



EICAR Malware payload

Authentication Manipulation for Phase 2

CHALMERS

- For Phase 2, we deliberately manipulated DNS records to test if Header-based allowslists allowlists override standard authentication checks.

TYPE	HOST	ANSWER	TTL	PRIO	ACTIONS
CNAME	em6134.venkatac.dev	u61358261.wl012.sendgrid.net	300	N/A	Edit Delete CREATED: 2026-03-24
CNAME	s1._domainkey.venkatac.dev	s1.domainkey.u61358261.wl012.sendgrid.net	300	N/A	Edit Delete CREATED: 2026-03-24
CNAME	s2._domainkey.venkatac.dev	s2.domainkey.u61358261.wl012.sendgrid.net	300	N/A	Edit Delete CREATED: 2026-03-24
TXT	_dmarc.venkatac.dev	v=DMARC1; p=none;	300	N/A	Edit Delete CREATED: 2026-03-24

Shared Infrastructure for Phase 3

CHALMERS

- For Phase 3, We sent payloads using a totally unrelated domain via a free-tier SendGrid account.
- We targeted the M365 sandbox, which had the SendGrid IP pool allowlisted.

SAT Provider	Attacker
sat@anasmasri.xyz	attacker@venkatac.dev
149.72.126.143	149.72.123.24

Domain Analysis for Phase 4

CHALMERS

- Reviewed public deployment guidelines and technical documentation across 7 major SAT platforms (KnowBe4, Cofense, Microsoft, Proofpoint, Hoxhunt, Infosec IQ, Barracuda).

Domain	Type	Registered	Registrar	Notes
landing.phishme.com	Landing	Yes	MarkMonitor	Simulation pages/assets

Whois Lookup

CHALMERS

phishme.com

Domain Information

Domain:	phishme.com
Registered On:	2007-02-27
Expires On:	2028-02-27
Updated On:	2026-01-26

Registrar Information

Registrar:	MarkMonitor Inc.
IANA ID:	292
Email:	https://www.markmonitor.com/contact-us/
Abuse Email:	abusecomplaints@markmonitor.com
Abuse Phone:	+1.2086851750

Production Validation for Phase 5

CHALMERS

- Obtained written approval from the Chalmers University IT security team before any testing began.
- Scope strictly limited to our own university mailboxes.
- Sent the same standardised payload set (P0–P3, short & long) via GoPhish.
- Only baseline testing was performed. Allowlist experiments (Phases 2 & 3) could not be replicated in this environment as we did not have administrative access to modify Exchange Transport Rules on the Chalmers tenant.
- **Goal:** Verify whether the baseline filtering patterns observed in the sandbox also appear in a real institutional mail environment, without modifying any production security policy.

Introduction & Background

Methodology & Setup

Results

Conclusion

Phase 1 Results - Baseline

CHALMERS

Category	Quarantine	Junk/Spam	Inbox
Benign (Short)		X	
Benign (Long)		X	
Spam (Short)		X	
Spam (Long)		X	
Phish (Short)		X	
Phish (Long)		X	
Malware (Long/Short)	X		

- **Result:** Emails from GoPhish were directly sent to Junk by default.

Phase 2 Results - Header Spoofing

CHALMERS

- We injected the `X-PHISHTEST` header into the exact same blocked emails.
- SPF, DKIM, and DMARC checks were failed, but still the emails went through.

Category	Quarantine	Junk/Spam	Inbox
Benign (Short)			X
Benign (Long)			X
Spam (Short)			X
Spam (Long)			X
Phish (Short)			X
Phish (Long)			X
Malware	X		

Authentication Override

CHALMERS

Raw Header Extraction (benign-short.eml):

```
Authentication-Results: spf=none (sender IP is 149.72.154.232)
smtp.mailfrom=em6134.venkatac.dev dkim=fail (no key for signature)
header.d=venkatac.dev dmarc=fail action=none
header.from=venkatac.dev compauth=fail reason=001
```

- A leak in a transport rule creates a backdoor for any external attacker.

Phase 3 Results

CHALMERS

We sent payloads using a totally unrelated domain via a free-tier SendGrid account, targeting the M365 sandbox which had the SendGrid IP pool allowlisted.

Category	Quarantine	Junk/Spam	Inbox
Benign, Spam, Phish			X
Malware	X		

Key Findings

CHALMERS

- The type of payload (P0, P1, P2) did not dictate where the email landed.
- The `X-PHISHTEST` rule (SCL = -1) overrode placement even when SPF, DKIM and DMARC were failed.
  Exception: The EICAR malware. Defender's malware detection overrides standard spam allowlists.
- The IP allowlist did not distinguish our authorized SendGrid account from an unrelated SendGrid account on the same IP pool.

Phase 4 - Domain Analysis Results

CHALMERS

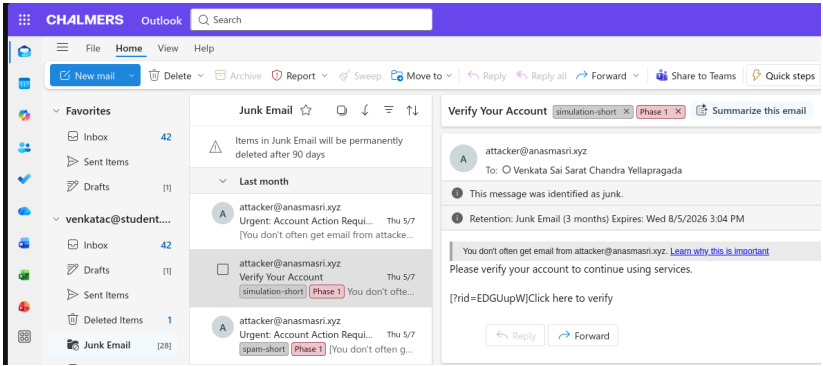
Core Stability vs. Peripheral Risk

- **Finding:** Zero unregistered domains were found among the primary vendor domain sets. Core infrastructure is actively managed.
- **The Real Risk:** Structural weaknesses exist around the edges of the ecosystem (legacy domains, placeholder domains in documentation, and shared third-party CDNs).
- **Delayed Threat:** Domains change ownership or expire over time, but outdated allowlist entries often remain permanently active in enterprise configurations.

Phase 5 - Production Validation (Baseline)

Testing in a Live Environment

- Execution was limited to Baseline Establishment; modifying production allowlists requires administrative access.



Phase 5 - Results

CHALMERS

- **Results:** Malware along with Long Spam and Phishing payloads that were successfully intercepted by Microsoft Defender and sent to Quarantine, rest were sent to Junk.

Category	Quarantine	Junk/Spam	Inbox
Benign (Short)		X	
Benign (Long)		X	
Spam (Short)		X	
Spam (Long)	X		
Phish (Short)		X	
Phish (Long)	X		
Malware (Long/Short)	X		

Introduction & Background

Methodology & Setup

Results

Conclusion

Answers to Research Questions

CHALMERS

- **RQ1:Can attackers bypass security measures by spoofing headers like X-PHISHTEST?**

  Yes, within our tested setup. All non-malware payloads reached the Inbox regardless of SPF, DKIM, or DMARC outcome.

- **RQ2: Can attackers abuse a SAT vendor's shared infrastructure to deliver malicious mail?**

  Yes, within our tested setup. An unrelated SendGrid account inherited the same allowlist trust as the authorised sender.

- **RQ3: How many default SAT domains are unregistered?**

  None in the reviewed dataset. Risk remains for legacy and undocumented domains over time.

Discussion: Limitations

- **Sandbox Environment:** Lacks the historical mail flow, user reporting, and reputation data of a mature corporate tenant to influence SCL.
- **Configuration Scope:** Tested standard SAT vendor guidelines, which may differ from highly customized enterprise setups.
- **Payload Variety:** Relied on standardized test strings (EICAR) rather than actual malware.
- **Domain Analysis:** Restricted to publicly documented vendor domains.

Discussion: Mitigation Strategies

CHALMERS

- **Avoid header-only allowlisting**
  Custom headers are unauthenticated and can be spoofed by any sender
- **Avoid broad IP allowlisting**
  Use dedicated vendor infrastructure over shared IP pools
- **Make allowlists temporary**
  Enable rules only during the active campaign window
- **Scope rules narrowly**
  Limit to specific recipients, senders, and time periods. this will reduces the impact of abuse.
- **Monitor and log usage**
  Alert on unexpected senders, timing, or volumes
- **Review domain allowlists regularly**
  Remove stale, expired, or unused simulation domains

Discussion: Future Work

CHALMERS

- **Wider range of SAT vendors and allowlisting configurations:** customer-specific sending domains, dedicated vendor infrastructure, and third-party secure email gateways. (Sandbox = real world)
- **additional phishing techniques:** credential-harvesting links, QR-code phishing, attachment formats other than EICAR, conversation hijacking, business email compromise templates, and payloads designed to evade link analysis.
- **lifecycle management of SAT:** measuring how often allowlist rules remain active after training campaigns, how frequently domains are reviewed, and whether administrators remove outdated vendor entries.
- **design and evaluate safer allowlisting mechanisms:** campaign-scoped rules, automatically expiring mail-flow rules, sender identity checks based on aligned DKIM, and monitoring systems that alert when SAT bypass rules are triggered outside approved training windows

Final Conclusions

CHALMERS

- SAT allowlists explicitly weaken email security by prioritizing delivery over standard content and identity evaluation.
- Header-based and IP-based allowlists can be bypassed by external attackers by spoofing custom markers (like `X-PHISHTEST`) or abusing shared cloud infrastructure.
- While primary vendor domains are actively managed, the complexity of SAT infrastructure requires organizations to actively monitor their allowlists to prevent trust in retired or abandoned domains.

Thank you

Questions?

References

[1] V. Bernard, Eye Security. *Microsoft's Attack Simulation Training: A Security Risk in Disguise*. Eye Security Blog, 2023.

[2] H. Xu et al. *BreakSPF: How Shared Infrastructures Magnify SPF Vulnerabilities Across the Internet*. NDSS Symposium, 2024.

[3] J. Klensin. *Simple Mail Transfer Protocol*. RFC 5321, IETF, 2008.

[4] Microsoft. *Microsoft Defender for Office 365 — Protection Stack*. Microsoft Learn, 2025.

[5] J. Roosen. *GoPhish: Open-Source Phishing Framework*. `https://getgophish.com`, 2023.